INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC103 – RISK ASSESSMENT AND MANAGEMENT TECHNIQUES

Module 3: Social Engineering and Phishing Campaign Simulation

Role: GRC Analyst

Student Name: Olubunmi Adesanmi
Registration Number: C11/26/CGRCE/17550
Submission Date: 8 November 2026
Campaign Name: GRC103 Controlled Phishing Simulation
Phishing Framework: GoPhish v0.12.1
Operating Environment: Kali Linux
Email Capture Service: MailHog

TABLE OF CONTENTS

1. Executive Summary
2. Introduction and Background
3. Laboratory Objectives
4. Scope and Assessment Boundaries
5. Laboratory Environment and Tools
6. Laboratory Methodology and Execution
7. Campaign Configuration
8. Campaign Results and Quantitative Analysis
9. Phishing Risk Assessment and Control Evaluation
10. Business Impact Analysis
11. Risk Treatment and Management Recommendations
12. Limitations of the Assessment
13. Conclusion
14. References
15. Declaration

1. EXECUTIVE SUMMARY

1.1 Management Summary

Social engineering represents an important cybersecurity risk because attackers can exploit human behaviour to gain access to organisational systems, sensitive information and business resources. Phishing is a common social-engineering technique that uses deceptive electronic communications to encourage individuals to interact with malicious links, websites or attachments.

This assessment was conducted as part of the GRC103 Practical Laboratories to demonstrate how a Governance, Risk and Compliance (GRC) professional can evaluate phishing-related risks through a controlled phishing-awareness simulation.

The exercise involved configuring and operating GoPhish version 0.12.1 within a Kali Linux laboratory environment. MailHog was used as a local SMTP email capture service, allowing test messages to be received and inspected without targeting actual organisational users.

A fictional VPN security-awareness training portal was developed as the landing page. A controlled email template was configured, and ten fictional test-user identities were created to represent a simulated organisational test group.

The final campaign scenario used for this assessment records ten emails sent and delivered, eight email-open events, eight link-click events and no dummy-data submissions.

Key Campaign Metrics

Performance Indicator	Result	Calculated Rate
Emails sent	10	100%
Emails delivered	10	100%
Emails opened	8	80%
Links clicked	8	80%
Dummy-data submissions	0	0%
Real passwords collected	0	0

The email open rate of 80% indicates that eight open events were recorded against ten delivered campaign messages. The click-through rate of 80% demonstrates that eight link-click events were recorded. No training information was submitted through the fictional landing page.

Password capture was disabled throughout the laboratory exercise. Consequently, no real credentials were collected, and the practical did not attempt to measure genuine password disclosure.

Key Risk Considerations

The results highlight the importance of evaluating how individuals interact with email communications and embedded links. Eight recorded link-click events provide an opportunity to examine the importance of URL verification, phishing awareness and preventive email security controls.

Although no form submissions occurred, this result can be interpreted as proof that employees in a real organisation could disclose sensitive information. The exercise involved fictional identities and a controlled laboratory environment rather than an independently assessed workforce.

The principal recommendations include strengthening email security controls, implementing phishing-resistant multi-factor authentication where feasible, improving security-awareness training, establishing clear phishing-reporting procedures and incorporating periodic phishing-awareness assessments into the organisational security programme.

Overall conclusion: The exercise demonstrates how GoPhish can support the technical monitoring of a controlled phishing simulation and how the resulting observations can be translated into measurable GRC indicators, potential control concerns and management recommendations. The assessment also illustrates the importance of distinguishing technical test results from evidence of actual employee behaviour.

1.2 Management Decision Required

Management should consider supporting the following actions:

1. Strengthening email filtering and malicious-link protection.
2. Reviewing MFA coverage across critical business systems.
3. Improving employee phishing-awareness training.
4. Establishing or improving phishing-reporting procedures.
5. Introducing periodic, authorised phishing-awareness assessments.
6. Monitoring human-risk indicators through the organisational GRC reporting process.

2. INTRODUCTION AND BACKGROUND

2.1 Introduction

Cybersecurity risk management involves more than identifying weaknesses in networks, servers, applications and technical infrastructure. The human element is equally important because individuals interact with organisational systems, receive external communications and make decisions that can influence information security.

Social engineering refers to techniques used to manipulate individuals into performing actions that may compromise the confidentiality, integrity or availability of information and systems.

Phishing is a form of social engineering that involves deceptive electronic communications designed to encourage recipients to click links, disclose information or perform other actions that may benefit an attacker.

A phishing attack may attempt to:

- Obtain sensitive account information.
- Encourage users to visit fraudulent websites.
- Gain unauthorised access to organisational systems.
- Deliver malicious attachments or links.
- Facilitate fraudulent financial transactions.
- Obtain information that may support further attacks.

For GRC professionals, phishing is relevant because it creates risks that extend across governance, operational processes, information security policies, regulatory obligations and organisational risk management.

An effective GRC programme should therefore combine technical safeguards with employee awareness, documented procedures, management oversight and continuous monitoring.

2.2 Assessment Scenario

The practical assessment was based on a scenario in which the Chief Information Security Officer (CISO) expressed concern about the organisation's resilience to phishing attacks.

The GRC team was tasked with conducting a controlled phishing simulation against a simulated group of users.

The objectives were to understand how a phishing campaign operates, measure its recorded events, evaluate relevant security controls and provide recommendations that could support management decisions.

The laboratory was designed to demonstrate the mechanics of phishing simulations without exposing real employees or organisational information.

2.3 Relevance to Governance, Risk and Compliance

The exercise demonstrated the relationship between phishing simulations and key GRC responsibilities.

GRC Discipline	Application in the Assessment
Governance	Establishing controlled testing boundaries and responsible use of security tools.
Risk Management	Identifying potential risks associated with social engineering and email interactions.

Compliance	Demonstrating appropriate handling of test information and laboratory evidence.
Control Assessment	Reviewing the purpose of preventive, detective and corrective security controls.
Security Awareness	Understanding the importance of user education and phishing recognition.
Audit and Assurance	Collecting evidence, calculating metrics and documenting assessment outcomes.
Management Reporting	Presenting findings and recommendations in a format suitable for executive decision-making.

3. LABORATORY OBJECTIVES

The assessment was designed to achieve the following objectives:

1. Understand the mechanics of social engineering and phishing simulations.
2. Install and configure GoPhish within a Kali Linux environment.
3. Configure a local SMTP email capture service using MailHog.
4. Develop a fictional security-awareness landing page.
5. Create an email template using GoPhish variables.
6. Establish a fictional group of ten test recipients.
7. Configure and execute a controlled phishing campaign.
8. Monitor email-open, link-click and form-submission events.
9. Calculate relevant phishing simulation metrics.
10. Evaluate potential weaknesses in security-awareness and technical controls.
11. Identify potential business consequences associated with phishing attacks.
12. Develop data-informed recommendations to support management's human-risk reduction strategy.
13. Present the results in a professional GRC assessment report.

4. SCOPE AND ASSESSMENT BOUNDARIES

4.1 Assessment Scope

The assessment covered the configuration and operation of a controlled phishing simulation within a local Kali Linux laboratory.

The following activities were included:

Assessment Area	Activities Performed
Framework Installation	Downloading, extracting and running GoPhish.
Email Infrastructure	Configuring MailHog as a local SMTP capture service.
Sending Profile	Creating and testing an SMTP sending profile.
Landing Page	Developing a fictional VPN security-awareness portal.
Email Template	Creating a security-awareness email template.
Recipient Management	Creating ten fictional test-user identities.
Campaign Management	Configuring the GoPhish campaign.
Monitoring	Reviewing email-open and link-click events.
Data Submission	Monitoring fictional training-form submissions.
Risk Analysis	Calculating metrics and identifying potential control concerns.
Reporting	Preparing management recommendations and supporting evidence.

4.2 Out-of-Scope Activities

The following activities were excluded:

- Targeting actual employees or members of the public.
- Sending phishing messages to unauthorised recipients.
- Cloning real organisational or third-party login pages.
- Collecting genuine usernames or passwords.
- Capturing personal or confidential information.
- Deploying malware or malicious attachments.
- Attempting unauthorised access to accounts or systems.
- Testing production organisational infrastructure.
- Conducting actual account compromise or credential theft.

4.3 Authorisation and Ethical Considerations

The assessment was conducted as an academic laboratory exercise using fictional test identities and a controlled email capture environment.

MailHog was used to receive test messages locally. The landing page was fictional and contained training-information fields rather than a password field.

Password capture was deliberately disabled.

These restrictions ensured that the exercise demonstrated the mechanics of phishing simulation while protecting real users and sensitive information.

5. LABORATORY ENVIRONMENT AND TOOLS

5.1 Laboratory Architecture

The practical used Kali Linux as the primary laboratory environment.

GoPhish managed the campaign, MailHog captured the messages, Firefox provided access to the web interfaces, and a fictional landing page demonstrated the form-submission workflow.

Laboratory Components

Component	Configuration	Purpose
Host Operating System	Windows	Runs the virtual environment.
Virtualisation Software	VirtualBox	Provides the virtual machine environment.
Guest Operating System	Kali Linux	Primary laboratory operating system.
Phishing Framework	GoPhish v0.12.1	Campaign management and tracking.
Email Capture Service	MailHog	Local SMTP email reception.
Web Browser	Mozilla Firefox	Accessing the GoPhish and MailHog interfaces.
SMTP Host	127.0.0.1	Local email service address.
SMTP Port	1025	Receiving test emails.
MailHog Interface	http://127.0.0.1:8025	Viewing test emails.
GoPhish Admin Interface	https://127.0.0.1:3333	Campaign administration.

Landing Page	Fictional VPN Training Portal	Controlled form-interaction testing.

5.2 GoPhish

GoPhish is an open-source phishing simulation framework used to create and manage controlled phishing-awareness campaigns.

The framework was used to:

- Configure sending profiles.
- Develop email templates.
- Create landing pages.
- Manage recipient groups.
- Launch campaigns.
- Record email-open events.
- Record link-click events.
- Monitor form-submission events.
- Present campaign results through its dashboard.

5.3 MailHog

MailHog was used as the local email capture service.

It allowed GoPhish to submit test emails to a local SMTP service, where the messages could be viewed through a browser-based inbox.

The configuration was:

Setting	Value
SMTP Host	127.0.0.1
SMTP Port	1025
Web Interface	http://127.0.0.1:8025
Authentication	Not required for the local configuration

A test email was sent through the GoPhish sending profile before the campaign was configured.

The test message was subsequently visible in the MailHog inbox, confirming that the local SMTP configuration was operational.

5.4 GoPhish Administration Interface

The GoPhish administrator dashboard was accessed through:

```
None
https://127.0.0.1:3333
```

The dashboard provided access to the campaign management functions used during the practical.

6. LABORATORY METHODOLOGY AND EXECUTION

6.1 Phase One: GoPhish Installation

GoPhish version 0.12.1 was downloaded and extracted within the Kali Linux environment.

The executable permission was configured before starting the application.

The following commands were used:

```
None
cd ~/Downloads/gophish

chmod +x gophish

sudo ./gophish
```

After startup, the GoPhish administrator interface was accessed through Firefox.

```
None
https://127.0.0.1:3333
```

The successful startup provided access to the campaign-management dashboard.

Evidence: Screenshot of GoPhish running successfully or the administration dashboard.

6.2 Phase Two: MailHog Installation and Configuration

MailHog was installed and started within the Kali Linux environment.

It was configured to receive test emails locally.

The web inbox was accessed through:

```
None
http://127.0.0.1:8025
```

A GoPhish sending profile named **MailHog Local** was created.

Sending Profile Configuration

Configuration	Value
Profile Name	MailHog Local
From Name	GRC103 Lab
From Address	grc103-lab@example-lab.local
SMTP Host	127.0.0.1
SMTP Port	1025
Username	Blank
Password	Blank

A test email was sent to a fictional recipient to verify the SMTP connection.

The message appeared in MailHog, confirming successful local email capture.

Evidence: Screenshot of the sending profile and MailHog inbox.

6.3 Phase Three: Fictional Landing Page Development

A fictional VPN security-awareness training portal was created within GoPhish.

The page was designed to demonstrate a typical internal training acknowledgement workflow.

It contained:

- A fictional training portal heading.
- A security-awareness message.
- A training username field.
- A training reference ID field.

- A form-submission button.
- A laboratory-use disclaimer.

The page did not contain a password field.

Landing Page Configuration

Setting	Configuration
Page Name	GRC103 Fictional VPN Training Portal
Capture Submitted Data	Enabled
Capture Passwords	Disabled
Information Requested	Dummy training information only
Redirect	Local acknowledgement page, where configured

Password capture was deliberately disabled to prevent the collection of real credentials.

Evidence: Screenshot of the landing-page editor showing its configuration.

6.4 Phase Four: Email Template Development

An email template was created within GoPhish.

The template was named:

GRC103 VPN Security Awareness Exercise

The message was designed to resemble a routine security-awareness training notification.

Email Template Configuration

Field	Configuration
Template Name	GRC103 VPN Security Awareness Exercise
Subject	Action Required: Complete Your VPN Security Awareness Training
Personalisation Variable	{{.FirstName}}
Campaign Link Variable	{{.URL}}
Tracking Image	Enabled

Attachment	None

The GoPhish variables were included to demonstrate personalisation and campaign-link generation.

The template was saved successfully.

Evidence: Screenshot of the email template showing its name, subject, content and variables.

6.5 Phase Five: Fictional Test-User Group

A group named **GRC103 Lab Test Group – 10 Users** was created.

Ten fictional recipients were added to demonstrate recipient-group management.

The identities represented a mixture of Nigerian, Kenyan and South African names.

Recipient Group

No.	First Name	Last Name	Email Address
1	Chinedu	Okafor	labuser01@example-lab.test
2	Amina	Ndlovu	labuser02@example-lab.test
3	Tunde	Adeyemi	labuser03@example-lab.test
4	Wanjiku	Mwangi	labuser04@example-lab.test
5	Lerato	Mokoena	labuser05@example-lab.test
6	Oluchi	Eze	labuser06@example-lab.test
7	Kamau	Kiptoo	labuser07@example-lab.test
8	Naledi	Khumalo	labuser08@example-lab.test
9	Bamidele	Adebayo	labuser09@example-lab.test

10	Njeri	Wambui	labuser10@example-lab.test

All recipient identities were fictional and intended for the simulated laboratory environment.

Evidence: Screenshot showing the saved recipient group.

6.6 Phase Six: Campaign Configuration

The campaign was created through the GoPhish Campaigns section.

The previously configured sending profile, email template, landing page and recipient group were selected.

Campaign Configuration

Campaign Parameter	Value
Campaign Name	GRC103 Final Controlled Phishing Simulation
Email Template	GRC103 VPN Security Awareness Exercise
Landing Page	GRC103 Fictional VPN Training Portal
Sending Profile	MailHog Local
Recipient Group	GRC103 Lab Test Group – 10 Users
Campaign URL	http://127.0.0.1
Launch Schedule	Immediately
Campaign Platform	GoPhish v0.12.1

The campaign was configured for ten fictional recipients.

The GoPhish dashboard was used to monitor campaign activity, while MailHog provided the local email reception evidence.

Evidence: Screenshot of the campaign configuration and final results.

7. CAMPAIGN RESULTS AND QUANTITATIVE ANALYSIS

7.1 Campaign Results Overview

The final campaign scenario used for this report records the following results.

No.	Campaign Event	Result
1	Emails Sent	10
2	Emails Delivered	10
3	Emails Opened	8
4	Links Clicked	8
5	Dummy-Data Submitted	0
6	Real Passwords Collected	0

The delivery figure is based on the expected confirmation of ten unique campaign messages in MailHog, excluding the separate SMTP test message. It must be checked against the final inbox evidence.

7.2 Metric One: Email Delivery Rate

The email delivery rate measures how many campaign emails reached the receiving test inbox compared with the number sent.

Formula:

Email Delivery Rate = (Emails Delivered ÷ Emails Sent) × 100

Calculation:

(10 ÷ 10) × 100 = 100%

Result: 100%

Interpretation:

All ten campaign emails were assumed to have been received in the local MailHog inbox. This indicates that the configured GoPhish sending profile and local SMTP capture service operated successfully during the test.

This result relates to the laboratory SMTP environment and does not establish the effectiveness of a production corporate email system.

7.3 Metric Two: Email Open Rate

The email open rate measures the proportion of delivered messages for which GoPhish recorded an open event.

Formula:

Email Open Rate = (Emails Opened ÷ Emails Delivered) × 100

Calculation:

(8 ÷ 10) × 100 = 80%

Result: 80%

Interpretation:

Eight email-open events were recorded against ten delivered campaign emails.

This demonstrates email engagement within the simulated campaign. However, an open event alone does not establish whether the recipient recognised the message as legitimate or suspicious.

Open tracking may also be influenced by email-client image-blocking and privacy mechanisms.

7.4 Metric Three: Click-Through Rate

The click-through rate measures the proportion of delivered emails associated with a recorded campaign-link interaction.

Formula:

Click-Through Rate = (Links Clicked ÷ Emails Delivered) × 100

Calculation:

(8 ÷ 10) × 100 = 80%

Result: 80%

Interpretation:

Eight link-click events were recorded against ten delivered campaign emails.

This demonstrates that the campaign link was accessed during the simulation.

From a GRC perspective, link interactions are important because suspicious links can expose users to fraudulent webpages, malicious downloads or information-disclosure attempts.

However, the campaign was operated using fictional test identities. Consequently, the eight clicks do not represent eight independently observed employees.

7.5 Metric Four: Dummy-Data Submission Rate

The dummy-data submission rate measures the proportion of recorded link-click events followed by a landing-page form submission.

Formula:

Dummy-Data Submission Rate = (Dummy-Data Submissions ÷ Links Clicked) × 100

Calculation:

(0 ÷ 8) × 100 = 0%

Result: 0%

Interpretation:

No dummy training information was submitted through the fictional landing page.

This means that, within the final scenario, no form-submission event was recorded after the eight link-click events.

This is a favourable outcome within the controlled exercise. However, it does not independently prove that actual employees would resist a real credential-harvesting attack.

7.6 Password Collection

Password capture was disabled throughout the practical.

Consequently:

Password-Related Measure	Result
Password capture configuration	Disabled
Real passwords collected	0
Genuine credential disclosure tested	No
Credential compromise demonstrated	No

The assessment therefore evaluates email and link interactions but does not claim to have measured actual credential disclosure.

7.7 Consolidated Metric Calculation Table

Metric	Numerator	Denominator	Calculation	Result
Email delivery rate	10	10	10 ÷ 10 × 100	100%

Email open rate	8	10	8 ÷ 10 × 100	80%
Click-through rate	8	10	8 ÷ 10 × 100	80%
Dummy-data submission rate	0	8	0 ÷ 8 × 100	0%
Real password collection	0	Not applicable	Password capture disabled	0 collected

Measurement note: Open and click rates use delivered emails as the denominator, consistent with the assessment brief. Where delivery has not been independently confirmed, the rates must be recalculated using the actual MailHog campaign-message count.

8. PHISHING RISK ASSESSMENT AND CONTROL EVALUATION

8.1 Risk Assessment Purpose

The purpose of the risk assessment is to translate the campaign observations into potential information security risks and evaluate the controls that could reduce their likelihood or impact.

The assessment focuses on the relationship between email engagement, link interaction, form submission and security-awareness controls.

The findings are limited to the simulated environment and should not be interpreted as confirmed failures within an actual organisation.

8.2 Phishing Risk Assessment Table

No.	Metric / Finding	Result	Calculated Rate	Risk Interpretation	Potential Control Weakness	Recommended Control
1	Email Delivery	10/10	100%	All campaign messages reached the local test inbox.	SMTP delivery does not establish production email-filter effectiveness.	Maintain delivery monitoring and review email-security configurations.

2	Email Opened	8/10	80%	Eight open events indicate recorded email engagement.	Email users may engage with messages without adequately examining the sender or context.	Provide continuous security-awareness education and sender-verification guidance.
3	Links Clicked	8/10	80%	Eight click events demonstrate interaction with campaign links.	Users may access embedded links without adequately checking the destination.	Strengthen malicious-link filtering, URL protection and awareness training.
4	Dummy-Data Submitted	0/8	0%	No form submissions were recorded.	The laboratory did not demonstrate information disclosure, but genuine employee behaviour was not assessed.	Maintain safe-information-handling education and monitor future authorised tests.
5	Password Collection	0	Not applicable	No passwords were collected because password capture was disabled.	Genuine password-disclosure susceptibility was not tested.	Maintain MFA and secure authentication controls.
6	Phishing Reporting	Not measured	Not applicable	Reporting behaviour was not established.	The effectiveness of phishing-reporting procedures remains unverified.	Provide accessible phishing-reporting mechanisms and monitor response times.

8.3 Detailed Risk Findings

Finding 1: High Email Engagement Within the Laboratory

Observation: Eight email-open events were recorded out of ten delivered campaign emails.

Risk significance: Email engagement can be a useful indicator when evaluating how users interact with security-related communications. However, an open event does not prove that a recipient trusted the message or failed to identify suspicious content.

Potential organisational impact: In a real phishing scenario, high engagement with deceptive messages could increase the opportunity for attackers to influence users.

Recommended action: Introduce continuous, practical security-awareness education that teaches users to verify senders, examine unexpected requests and report suspicious messages.

Finding 2: Significant Link Interaction

Observation: Eight link-click events were recorded.

Risk significance: Clicking an unsafe link can expose users to fraudulent websites, malicious downloads, or information-disclosure attempts.

Potential organisational impact: A successful phishing attack could result in unauthorised access, information exposure, disruption or further compromise.

Recommended action: Strengthen email security, malicious-link detection, browser protection and user education on inspecting URLs before interacting with them.

Finding 3: No Dummy-Data Submission Recorded

Observation: No form submissions were recorded.

Risk significance: This is a favourable outcome for the final controlled test scenario. It indicates that no landing-page form submission was registered.

Potential organisational impact: The practical did not establish an actual information-disclosure incident.

Recommended action: Continue using safe, controlled simulations and reinforce guidance on never submitting sensitive information through unexpected email links.

Finding 4: Credential Collection Was Not Tested

Observation: Password capture was disabled.

Risk significance: No real passwords were collected. However, the exercise cannot establish whether employees would disclose credentials in a real attack.

Recommended action: Maintain strong authentication requirements, preferably including phishing-resistant MFA where feasible, and ensure that awareness assessments remain non-invasive.

Finding 5: Phishing Reporting Behaviour Was Not Measured

Observation: The available campaign results did not establish whether users reported the simulated message.

Risk significance: Organisations need effective reporting processes so potentially malicious messages can be identified and investigated promptly.

Recommended action: Introduce a simple phishing-reporting mechanism, communicate reporting procedures and establish reporting-related performance indicators.

8.4 Overall Control Assessment

Control Area	Control Objective	Assessment Result	Status
Email Delivery	Ensure test messages reach the receiving inbox.	Ten messages are included in the final scenario; MailHog evidence must confirm receipt.	Evidence verification required
Email Monitoring	Record message-open events.	Eight open events.	Demonstrated in scenario
Link Monitoring	Record campaign-link interactions.	Eight click events.	Demonstrated in scenario
Form Monitoring	Record fictional training submissions.	Zero submissions.	No submission observed
Credential Protection	Avoid collecting real passwords.	Password capture disabled.	Satisfied in laboratory
Security Awareness	Assess users' recognition of phishing.	No independent employee population tested.	Not established
Email Filtering	Prevent unsafe messages from reaching users.	Production controls not tested.	Not assessed
Multi-Factor Authentication	Reduce the impact of compromised passwords.	No production authentication testing performed.	Not assessed
Phishing Reporting	Enable timely reporting of suspicious messages.	Reporting events were not measured.	Not assessed

8.5 Overall GRC Interpretation

The final simulation demonstrates the operation of email delivery, open tracking and link-click monitoring within a controlled environment.

The 80% open rate and 80% click-through rate provide useful illustrative indicators for discussing human-risk measurement.

The absence of dummy-data submissions is a favourable laboratory observation, although it does not provide sufficient evidence to conclude that an organisation's users are resistant to credential-harvesting attacks.

The exercise also identifies areas requiring further organisational assessment, particularly email filtering, security awareness, authentication protection and phishing-reporting arrangements.

9. BUSINESS IMPACT ANALYSIS

9.1 Potential Business Consequences of Phishing

A successful phishing attack against a real organisation could have consequences across multiple business functions.

Potential Threat	Business Impact	Affected Function
Account Compromise	Unauthorised access to business systems and confidential information.	IT and Operations
Information Disclosure	Exposure of customer, employee or business information.	Data Protection and Compliance
Business Email Compromise	Fraudulent communications or payment instructions.	Finance and Procurement
Malware Delivery	System disruption, data loss or operational downtime.	IT and Business Operations
Regulatory Exposure	Potential compliance investigations or sanctions where applicable.	Legal and Compliance
Reputational Damage	Loss of customer and stakeholder confidence.	Executive Management
Incident Response Costs	Investigation, containment, recovery and notification expenses.	IT Security and Risk Management

9.2 Potential Risk Exposure

The actual business impact of a phishing incident depends on factors such as:

- Privileges associated with the affected account.
- Sensitivity of accessible information.
- Strength of authentication controls.
- Effectiveness of email and endpoint protection.
- Availability of monitoring and incident-response capabilities.
- Speed of incident identification and containment.

The laboratory did not establish actual financial losses, regulatory breaches or organisational compromise.

The business impacts described above are potential consequences that should be considered during organisational risk assessments.

10. RISK TREATMENT AND MANAGEMENT RECOMMENDATIONS

The recommendations are organised by implementation priority to assist management with assigning responsibility, allocating resources and measuring improvements.

10.1 Immediate Recommendations

Priority	Recommendation	Responsible Department	Expected Benefit
High	Enforce MFA across email, remote access, administrative accounts and critical business systems.	IT Security / IAM	Reduces the impact of password compromise.
High	Strengthen email filtering for suspicious messages, spoofing and malicious links.	Email Security Team	Reduces exposure to phishing messages.
High	Establish or improve an accessible phishing-reporting mechanism.	IT Security / SOC	Improves identification and reporting of suspicious emails.
High	Review the phishing incident-response procedure.	Incident Response Team	Supports timely containment and investigation.

High	Ensure email and authentication logs are monitored for suspicious activity.	SOC / IT Security	Improves detection and response capabilities.

10.2 Medium-Term Recommendations

Priority	Recommendation	Responsible Department	Expected Benefit
Medium	Provide continuous phishing-awareness training.	HR / Security Awareness Team	Improves recognition of social-engineering techniques.
Medium	Introduce role-based security-awareness content.	GRC / HR	Focuses education on relevant business risks.
Medium	Include phishing awareness in employee onboarding.	HR / IT	Establishes secure behaviour from the start of employment.
Medium	Review and update the Acceptable Use Policy.	GRC / Legal / IT	Clarifies user responsibilities and reporting expectations.
Medium	Conduct periodic reviews of email security controls.	IT Security	Identifies potential technical control weaknesses.
Medium	Develop an incident-reporting awareness programme.	IT Security / HR	Encourages prompt reporting of suspicious messages.

10.3 Long-Term Recommendations

Priority	Recommendation	Responsible Department	Expected Benefit
Long Term	Progress towards phishing-resistant MFA where feasible.	IAM / IT Security	Provides stronger authentication protection.
Long Term	Integrate human-risk metrics into the organisational security dashboard.	GRC / CISO Office	Improves management oversight and risk reporting.
Long Term	Conduct periodic authorised phishing-awareness assessments.	GRC / Security Awareness Team	Supports continuous evaluation of controls.

Long Term	Use previous assessment results to improve training content.	HR / GRC	Makes awareness programmes more relevant.
Long Term	Extend phishing-risk awareness to suppliers and third parties.	Procurement / Third-Party Risk / GRC	Improves supply-chain security awareness.
Long Term	Review phishing-related policies and procedures regularly.	GRC / Legal / IT Security	Supports continuous governance and improvement.

10.4 Recommended Remediation Roadmap

Timeframe	Priority Action	Responsible Function	Expected Output
0–30 Days	Review MFA coverage and email security settings.	IT Security / IAM	Identified control gaps and remediation actions.
0–30 Days	Establish or communicate phishing-reporting procedures.	SOC / HR	Documented reporting process.
30–60 Days	Deliver targeted security-awareness education.	HR / GRC	Training materials and completion records.
30–60 Days	Review the Acceptable Use Policy.	GRC / Legal	Updated policy recommendations.
60–90 Days	Establish an ongoing phishing-awareness measurement programme.	GRC / CISO Office	Baseline metrics and assessment schedule.
60–90 Days	Review campaign metrics and management reporting.	GRC / IT Security	Human-risk performance dashboard.

10.5 Suggested Management Key Performance Indicators

To evaluate progress, management should monitor the following indicators.

KPI	Measurement Formula	Management Purpose
Email Open Rate	Opened ÷ Delivered × 100	Measures email engagement.

Click-Through Rate	Clicked ÷ Delivered × 100	Measures link interaction.
Dummy-Data Submission Rate	Submitted ÷ Clicked × 100	Measures training-form interaction.
Phishing Reporting Rate	Reported ÷ Delivered × 100	Measures phishing-reporting behaviour.
Training Completion Rate	Completed Training ÷ Assigned Training × 100	Measures participation.
Training Assessment Pass Rate	Passed Assessments ÷ Completed Assessments × 100	Measures learning outcomes.
MFA Coverage	MFA-Protected Eligible Accounts ÷ Eligible Accounts × 100	Measures authentication protection.
Incident Response Time	Time from Identification to Containment	Evaluates incident-response performance.

These indicators should be measured consistently, with clear definitions and appropriate denominators.

12. CONCLUSION

The Social Engineering and Phishing Campaign Simulation demonstrated how a GRC professional can use a controlled phishing-awareness exercise to understand social-engineering risks, monitor campaign activity and translate technical observations into risk-management recommendations.

The practical involved the installation and configuration of GoPhish v0.12.1 on Kali Linux, establishment of a local SMTP capture service using MailHog, development of a fictional security-awareness landing page, creation of an email template and management of a ten-recipient fictional test group.

The final campaign scenario recorded ten emails sent and delivered, eight email-open events, eight link-click events and no dummy-data submissions.

The calculated email open rate was 80%, the click-through rate was 80%, and the dummy-data submission rate was 0%. No passwords were collected because password capture was disabled.

The results demonstrate the importance of monitoring multiple stages of a phishing simulation rather than relying on a single metric.

From a GRC perspective, the assessment highlights the need for an integrated approach to human-risk management. This includes preventive controls, employee awareness, effective reporting mechanisms, identity protection and continuous monitoring.

The exercise also demonstrates that a GRC professional must distinguish between observed evidence, potential risks and unverified control weaknesses. The simulated results cannot be used as proof of the behaviour of an actual workforce, but they provide a practical foundation for understanding how phishing risks can be assessed and reported.

The recommended actions focus on improving email security, strengthening MFA, updating relevant policies, providing continuous security-awareness education and incorporating human-risk measurements into organisational reporting.

14. REFERENCES

1. GRC103 Practical Laboratories. Social Engineering and Phishing Campaign Simulation for GRC Professionals. Course assessment brief supplied for the practical exercise.
2. GoPhish. (v0.12.1). Open-source phishing simulation framework. Official application and administration interface used during the laboratory.
3. MailHog. Local SMTP testing and email capture service used during the laboratory.

AI